Laboratoire - Comparaison des méthodologies de tests d'intrusion

Partie 1 : Effectuer des recherches sur les méthodologies de pentesting les plus courantes

• OSSTMM

>Le manuel OSSTMM (Open-Source Security Testing Methodology Manual) est l'une des normes les plus utilisées en matière de tests d'intrusion. Il s'agit d'une méthodologie de test de sécurité élaborée par l'Institute for Security and Open Methodologies (ISECOM) et évaluée par les pairs.

Cette méthode s'appuie sur une approche scientifique des tests d'intrusion accompagnée de guides accessibles et adaptables aux testeurs. La méthodologie OSSTMM met l'accent sur l'aspect opérationnel, les tests de canaux, les indicateurs et l'analyse de la confiance.

L'OSSTMM fournit aux spécialistes du pentest un cadre pour les tests d'intrusion réseau et l'évaluation des vulnérabilités. Ce cadre vise à aider les fournisseurs à trouver et à corriger des vulnérabilités telles que les données sensibles et les problèmes d'authentification.

• PTES

>Le PTES est un ensemble de règles standardisées qui encadre tous les processus de tests d'intrusion. En réalité, les tests d'intrusion sont pratiqués depuis un certain temps déjà, mais à l'origine, les règles et réglementations encadrant les testeurs d'intrusion étaient peu nombreuses. Les entreprises ne sachant pas à quoi s'attendre lors d'un test d'intrusion, les résultats étaient peu cohérents. Le piratage éthique était encore considéré comme un piratage peu encadré et dont le contrôle qualité était limité, voire inexistant

• OWASP WSTG

>OWASP WSTG (Web Security Testing Guide) est un guide complet destiné à tester la sécurité des applications web et des services web. Voici quelques points clés à propos de ce guide -----Le WSTG vise à fournir un cadre de meilleures pratiques pour les tests de sécurité, permettant aux professionnels de la sécurité d'évaluer la robustesse des applications web

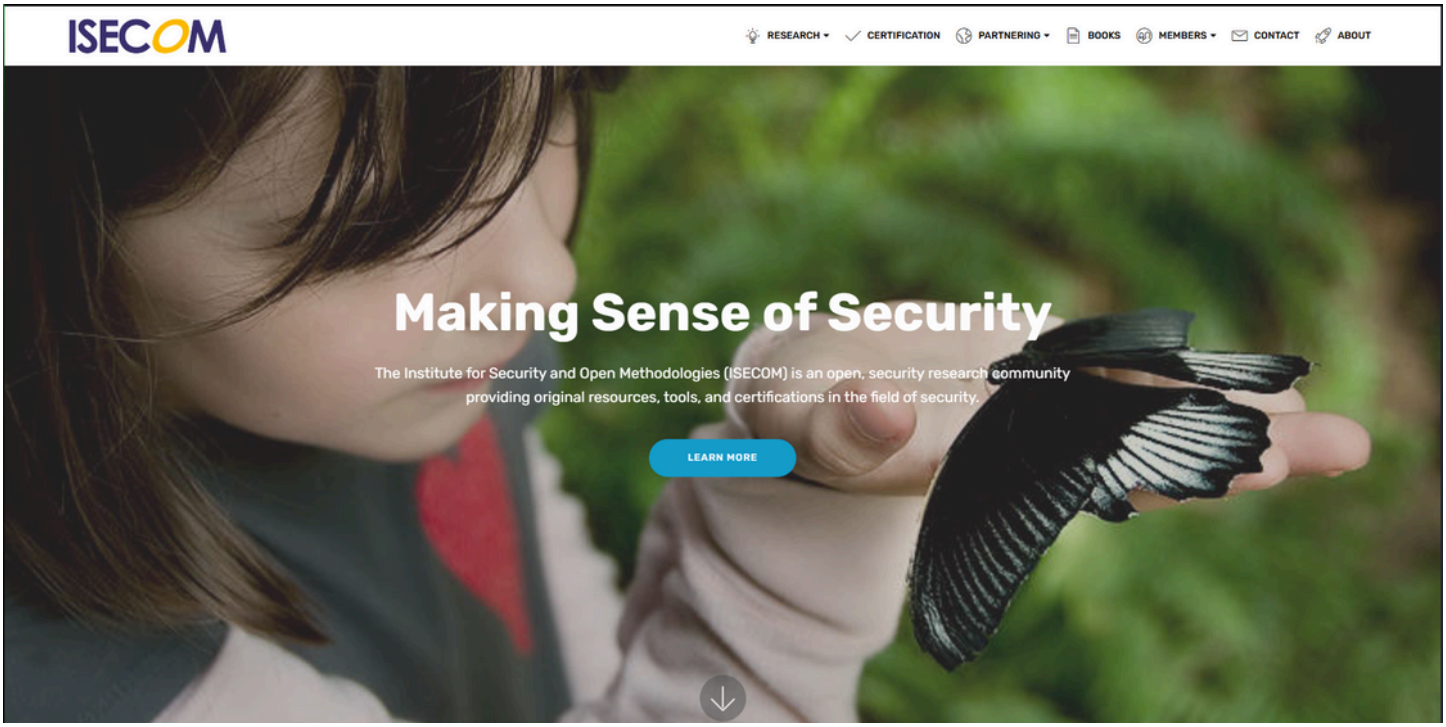
• MITRE ATT&CK

>Le **MITRE ATT&CK** est une base de connaissances qui modélise les tactiques et techniques des cyber-adversaires. MITRE ATT&CK vise à aider les organisations à comprendre comment les attaquants opèrent, ce

qui leur permet de mieux se défendre contre les cybermenaces.

Étape 1 : Rassemblez des informations sur l'OSSTMM

a. Accédez à https://www.isecom.org , cliquez sur RECHERCHE > OSSTMM



b. Sur la page principale de l'OSSTMM, consultez le document OSSTMM



Au debut du document nous pouvons remarquer qu'on est a la 3eme version du manuel



ici nous pouvons remarquer que la date de copyright est de 2010

Quel organisme développe l'OSSTMM ? Que fait-il ?

>L'OSSTMM est développée par l'ISECOM (Institute for Security and Open Methodologies).
Cet organisme est dédié à la recherche et à la promotion des meilleures pratiques en matière de sécurité informatique.

L'ISECOM se concentre sur :

-La création de méthodologies ouvertes pour les tests de sécurité.

-La formation et l'éducation des professionnels de la sécurité.

-La publication de ressources et de guides pour aider les organisations à évaluer et à améliorer leur sécurité

Quels sont les objectifs principaux et secondaires déclarés de l'OSSTMM tels qu'énoncés dans la publication de l'OSSTMM ?

>Les objectifs de l'OSSTMM, tels qu'énoncés dans sa publication sont :

-Évaluation de la sécurité : Fournir une méthode systématique pour évaluer la sécurité des systèmes d'information.

-Standardisation : Établir des normes pour les tests de sécurité afin d'assurer la cohérence et la fiabilité des résultats.

Quels sont les six résultats assurés pour que les directives de l'OSSTM soient correctement suivies ?

>-Clarté des objectifs : Les objectifs de sécurité doivent être clairement définis et compris par toutes les parties prenantes.

-Documentation complète : Tous les processus et résultats doivent être documentés de manière exhaustive pour assurer la traçabilité.

-Conformité aux normes : Les tests doivent être conformes aux normes de l'industrie et aux réglementations pertinentes.

-Formation adéquate : Les équipes impliquées dans les tests doivent recevoir une formation appropriée pour comprendre et appliquer les méthodologies.

-Évaluation continue : Un processus d'évaluation continue doit être en place pour ajuster les méthodes et les pratiques en fonction des résultats obtenus.

-Amélioration des processus : Les résultats des tests doivent être utilisés pour améliorer les processus de sécurité et réduire les vulnérabilités.

Quelles sont les dix étapes de l'application de l'OSSTM lorsque le processus en 4 points et le Trifecta sont combinés ?

>-Préparation : Définir le périmètre et comprendre le contexte du système à tester.

-Collecte de données : Rassembler des informations sur les opérations normales pour mieux comprendre la cible.

-Évaluation des risques : Identifier les surfaces de risque et les vulnérabilités potentielles.

-Tests de sécurité : Effectuer des tests en utilisant les méthodologies définies pour évaluer la sécurité.

-Analyse des résultats : Examiner les résultats des tests pour identifier les failles de sécurité.

-Rapport : Documenter les résultats et les recommandations dans un rapport clair et concis.

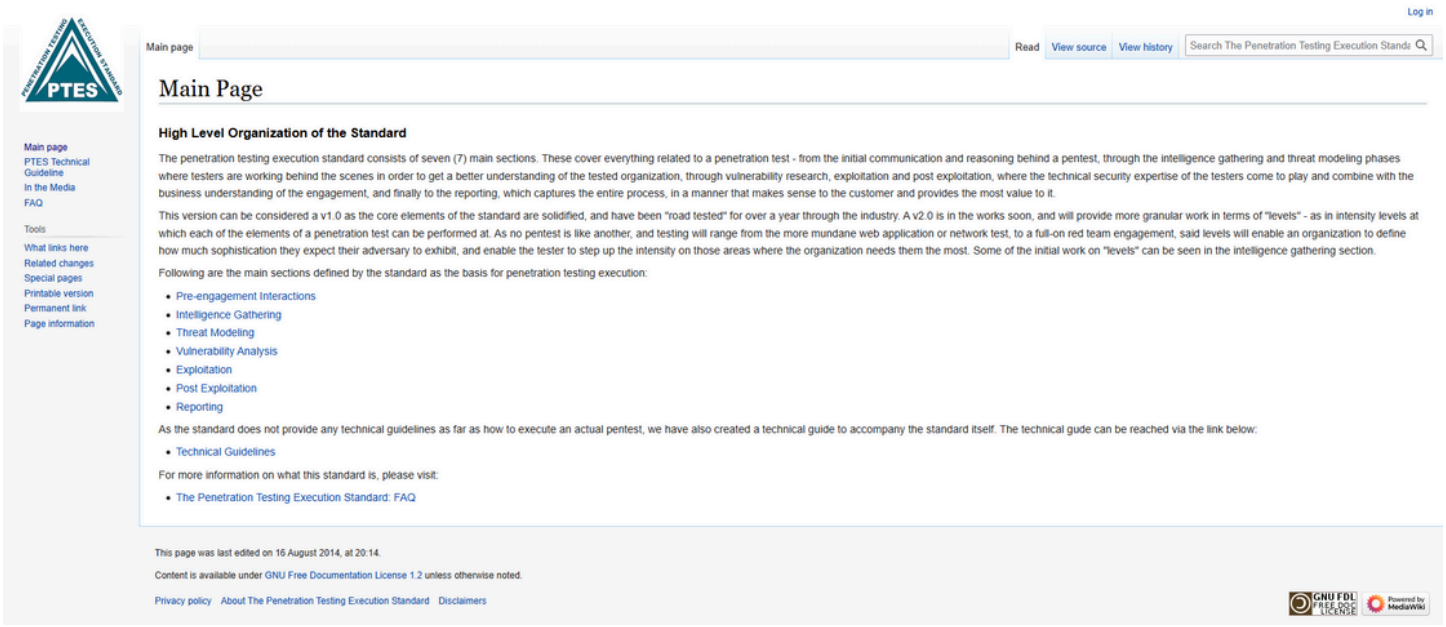
-Révision des processus : Évaluer les processus de sécurité existants et les ajuster en fonction des résultats.

-Mise en œuvre des améliorations : Appliquer les recommandations pour renforcer la sécurité.

-Formation continue : Assurer une formation continue pour les équipes sur les nouvelles menaces et techniques.

-Suivi et réévaluation : Mettre en place un suivi régulier et réévaluer les mesures de sécurité pour s'assurer de leur efficacité.

Étape 2 : Rassemblez des informations sur PTES.



Quelle est la dernière version de la norme ?

>La derniere version de la norme est la version 1.0

Quelles sont les sept sections principales du PTES ?

>-Préparation : Cette section concerne la planification et la définition des objectifs du test.

-Collecte d'informations : Rassembler des données sur la cible pour mieux comprendre son environnement.

-Évaluation des vulnérabilités : Identifier les failles potentielles dans le système.

-Exploitation : Tenter d'exploiter les vulnérabilités identifiées pour accéder aux systèmes.

-Post-exploitation : Évaluer l'impact de l'exploitation et déterminer la portée de l'accès obtenu.

-Rapport : Documenter les résultats, les méthodes utilisées et les recommandations.

-Suivi : Vérifier que les recommandations ont été mises en œuvre et évaluer l'efficacité des mesures prises.

Quel est l'objectif déclaré du PTES ? (Indice : consultez la FAQ)

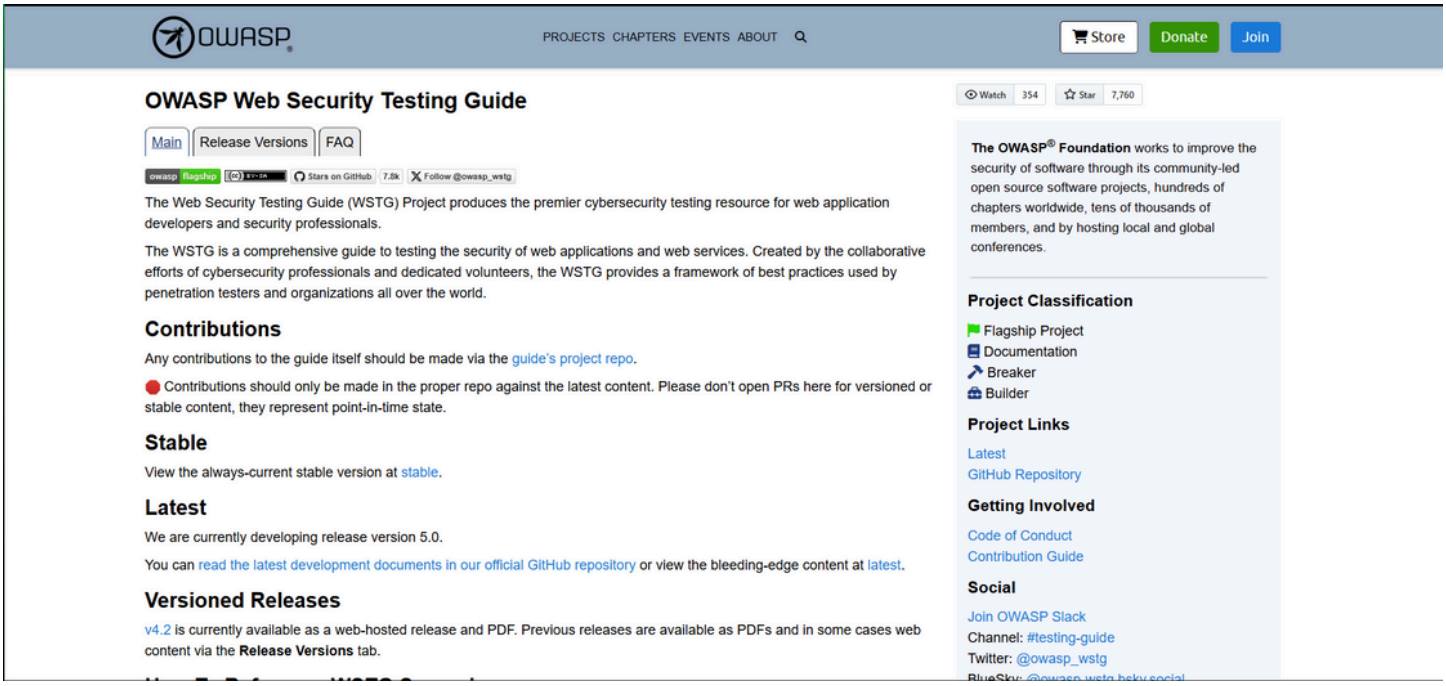
>L'objectif principal du PTES est de fournir un cadre standardisé pour la réalisation de tests de pénétration, permettant aux testeurs de déterminer la manière la plus efficace de mener un test en fonction des besoins de leur organisation. Cela inclut la documentation des méthodes et des résultats pour assurer la transparence et la compréhension des processus.

Quel document précise les outils et techniques à utiliser dans les sept sections du test ?

>Le document qui précise les outils et techniques à utiliser dans les sept sections du test est généralement le PTES Technical Guidelines. Ce document fournit des directives techniques détaillées

pour chaque phase du test, aidant ainsi les testeurs à suivre des procédures appropriées.

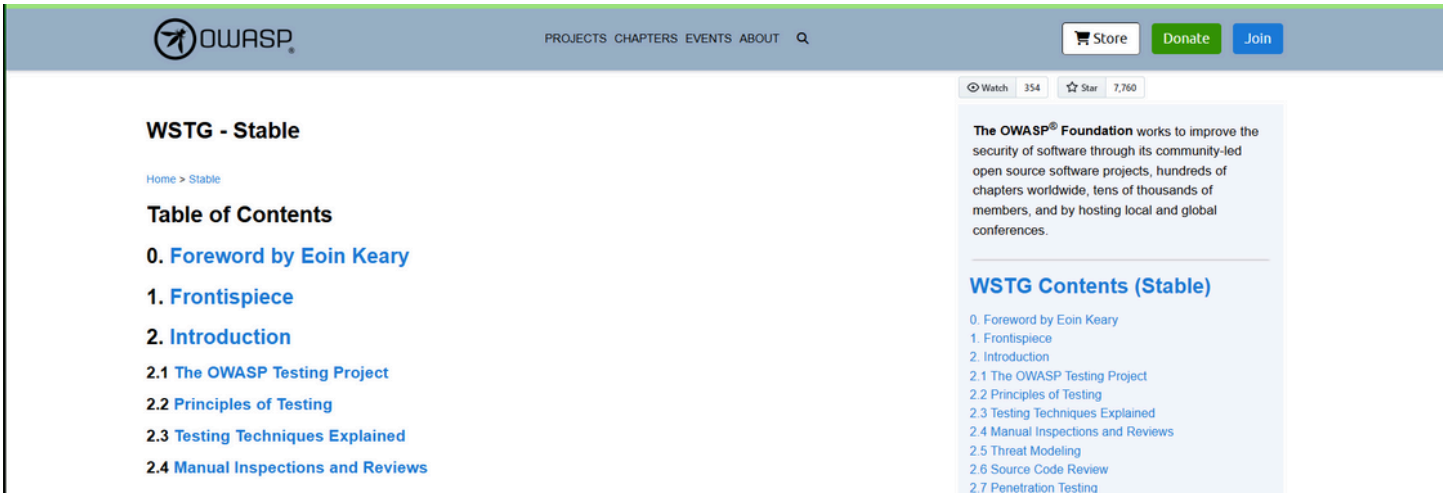
Étape 3 : Rassemblez des informations sur l'OWASP WSTG:



Quelle est la dernière version de la norme WSTG ?

>La derniere version de la norme est la version 4.2

Accédez à la version stable actuelle du WSTG. Quelles sont les cinq phases du cadre de test de sécurité Web ?



>-Préparation : Planification et définition des objectifs du test.

-Collecte d'informations : Rassembler des données sur la cible pour mieux comprendre son environnement.

-Évaluation des vulnérabilités : Identifier les failles potentielles dans le système.

-Exploitation : Tenter d'exploiter les vulnérabilités identifiées pour accéder aux systèmes.

-Rapport : Documenter les résultats, les méthodes utilisées et les recommandations.

Quel est l'objectif déclaré de l'OWASP WSTG ?

>L'objectif principal de l'OWASP WSTG est de fournir un cadre standardisé pour la réalisation de tests de sécurité des applications web. Cela inclut la documentation des méthodes et des résultats pour assurer la transparence et la compréhension des processus de test.

Quelles sont les douze catégories de tests actifs définis dans le framework de test Web OWASP ?

>-Défaillances cryptographiques

-Failles d'injection (comme XSS, SQL, SSTI, etc.)

-Conception et architecture défaillantes

-Configuration incorrecte de la sécurité

-Exposition de données sensibles

-Mauvaise gestion des sessions

-Mauvaise validation des entrées

-Failles de sécurité dans les API

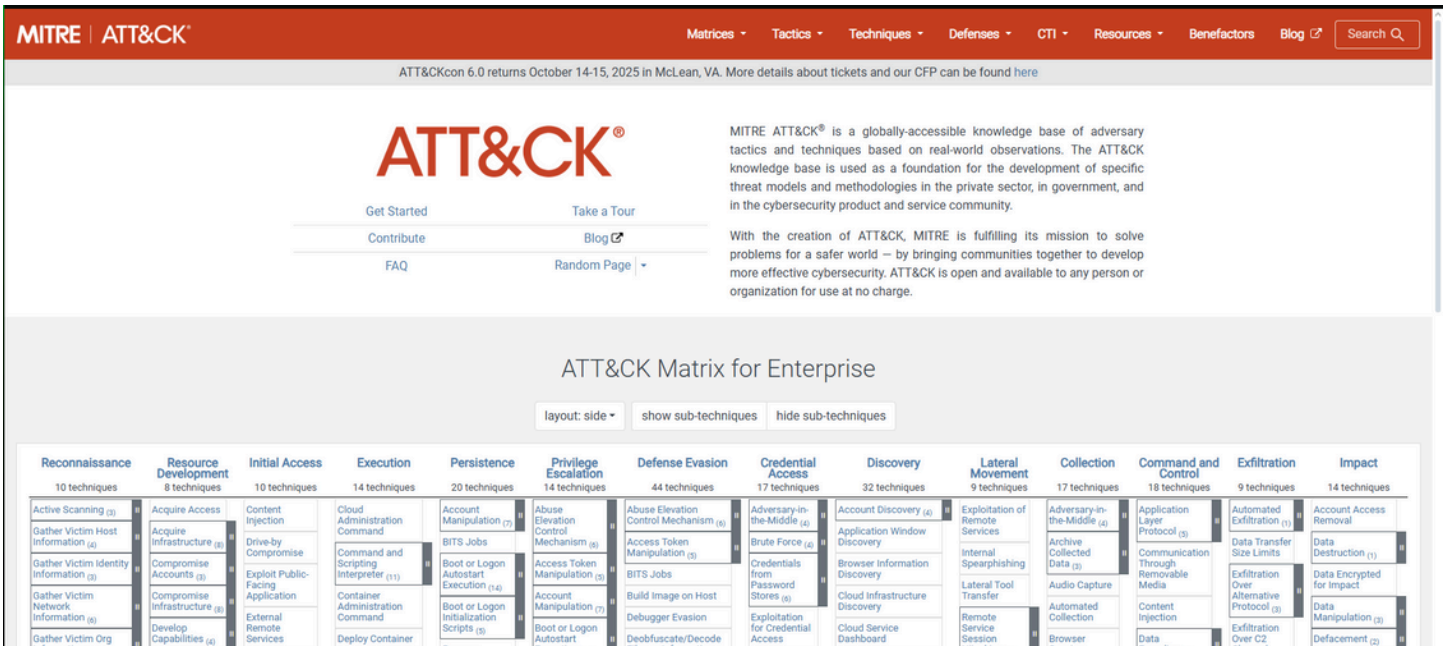
-Problèmes de sécurité dans les services tiers

-Attaques par déni de service

-Vulnérabilités liées à la chaîne d'approvisionnement

Étape 4 : Rassemblez des informations sur MITRE ATT&CK :

a. Accédez à https://attack.mitre.org .



Quelle est la dernière version de la norme ATT&CK ?

>La derniere version est la version 16.**1**

Pourquoi MITRE a-t-il développé ATT&CK ? (Indice : consultez la FAQ)

>MITRE a développé le cadre ATT&CK pour fournir une base de connaissances sur les tactiques et techniques utilisées par les adversaires en cybersécurité

b. Dans le menu de la page, cliquez sur Ressources > Informations générales > Conception et philosophie ATT&CK .

>

c. Ouvrez et examinez le PDF ATT&CK Design and Philosophy. Quels sont les six cas d'utilisation courants d'ATT&CK décrits ?

>-Développement de la détection : Créer des règles de détection basées sur les techniques ATT&CK.

-Réponse aux incidents : Utiliser ATT&CK pour comprendre les tactiques et techniques utilisées lors d'un incident.

-Formation et sensibilisation : Éduquer les équipes de sécurité sur les menaces et les techniques adverses.

-Tests de pénétration : Utiliser ATT&CK pour simuler des attaques et tester les défenses.

-Planification de la sécurité : Aider à la priorisation des investissements en sécurité en fonction des menaces identifiées.

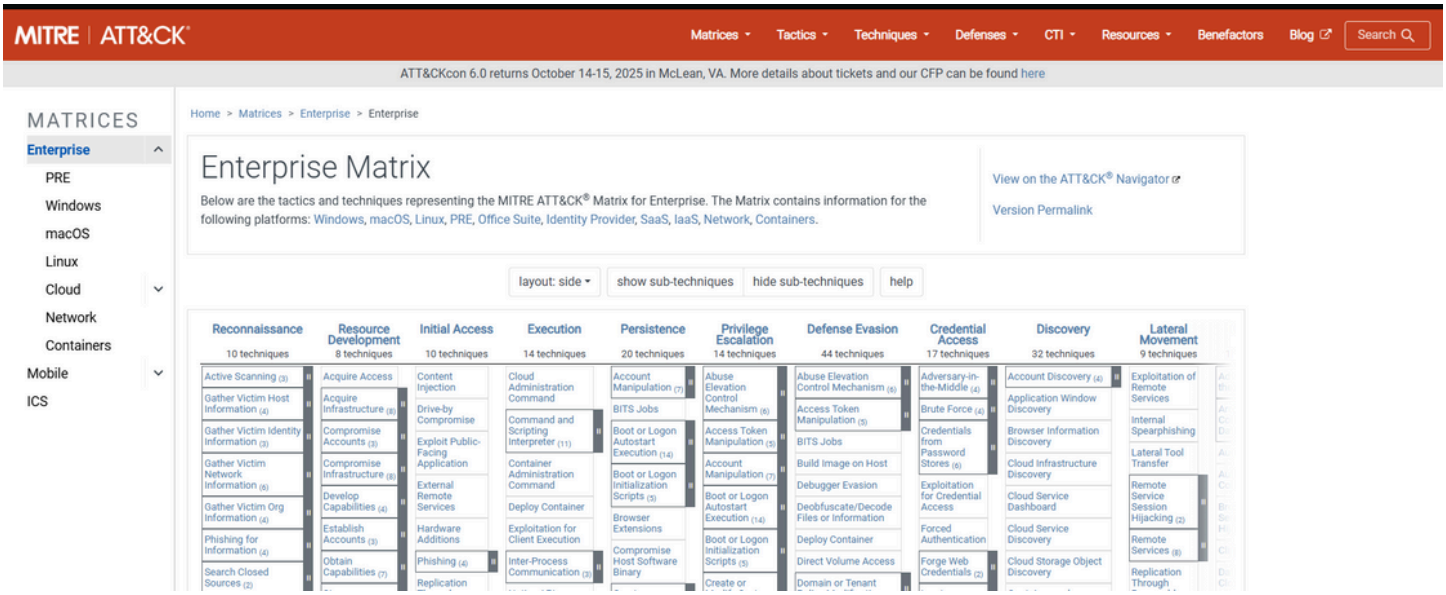
Quels sont les trois domaines technologiques d'ATT&CK ?

>-Enterprise : Techniques et tactiques pour les environnements d'entreprise.

-Mobile : Techniques spécifiques aux appareils mobiles.

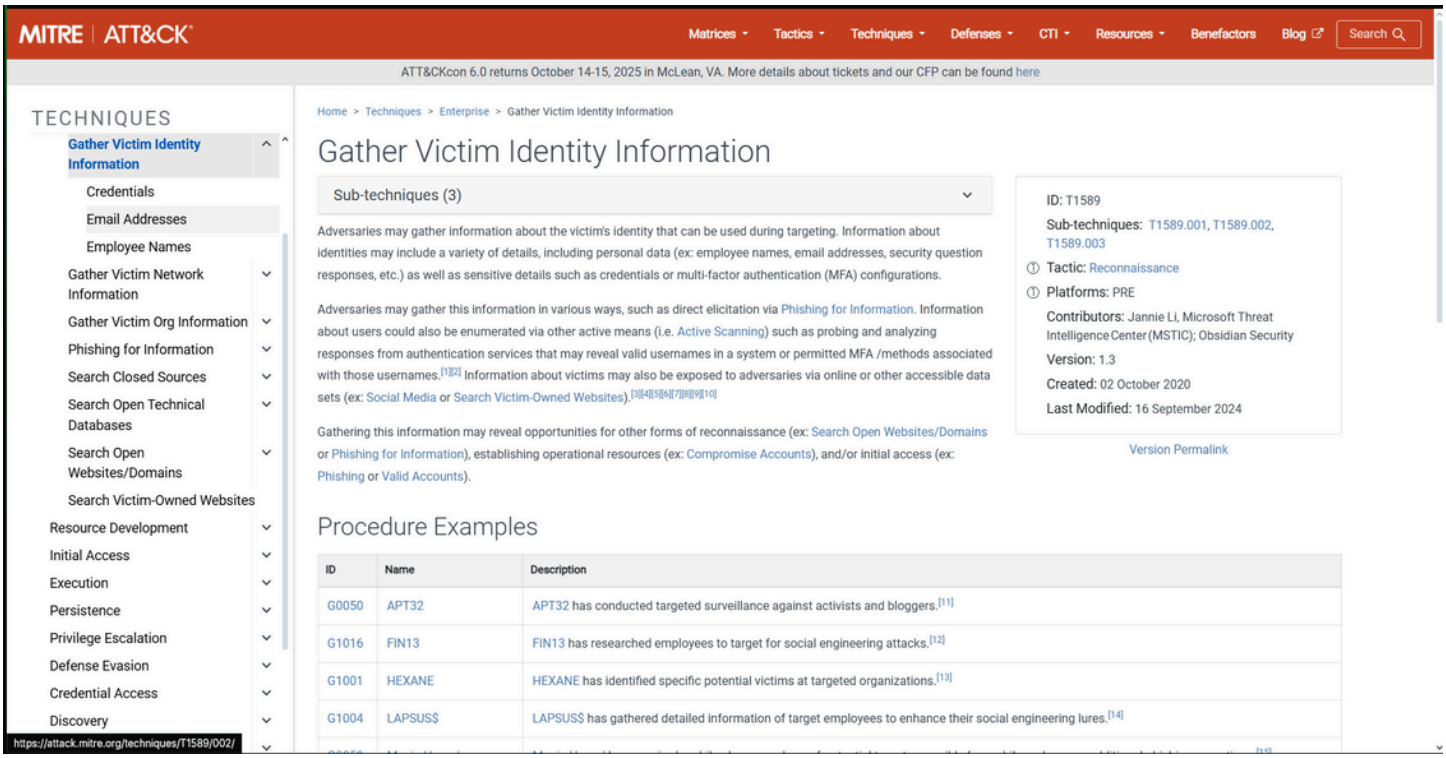
-ICS (Industrial Control Systems) : Techniques pour les systèmes de contrôle industriel.

d. Accédez à la matrice MITRE ATT&CK Enterprise en ouvrant le menu Matrices et en choisissant Enterprise .



>

e. Dans la colonne Tactique de reconnaissance, cliquez sur l' entrée Recueillir les informations sur l'identité de la victime .



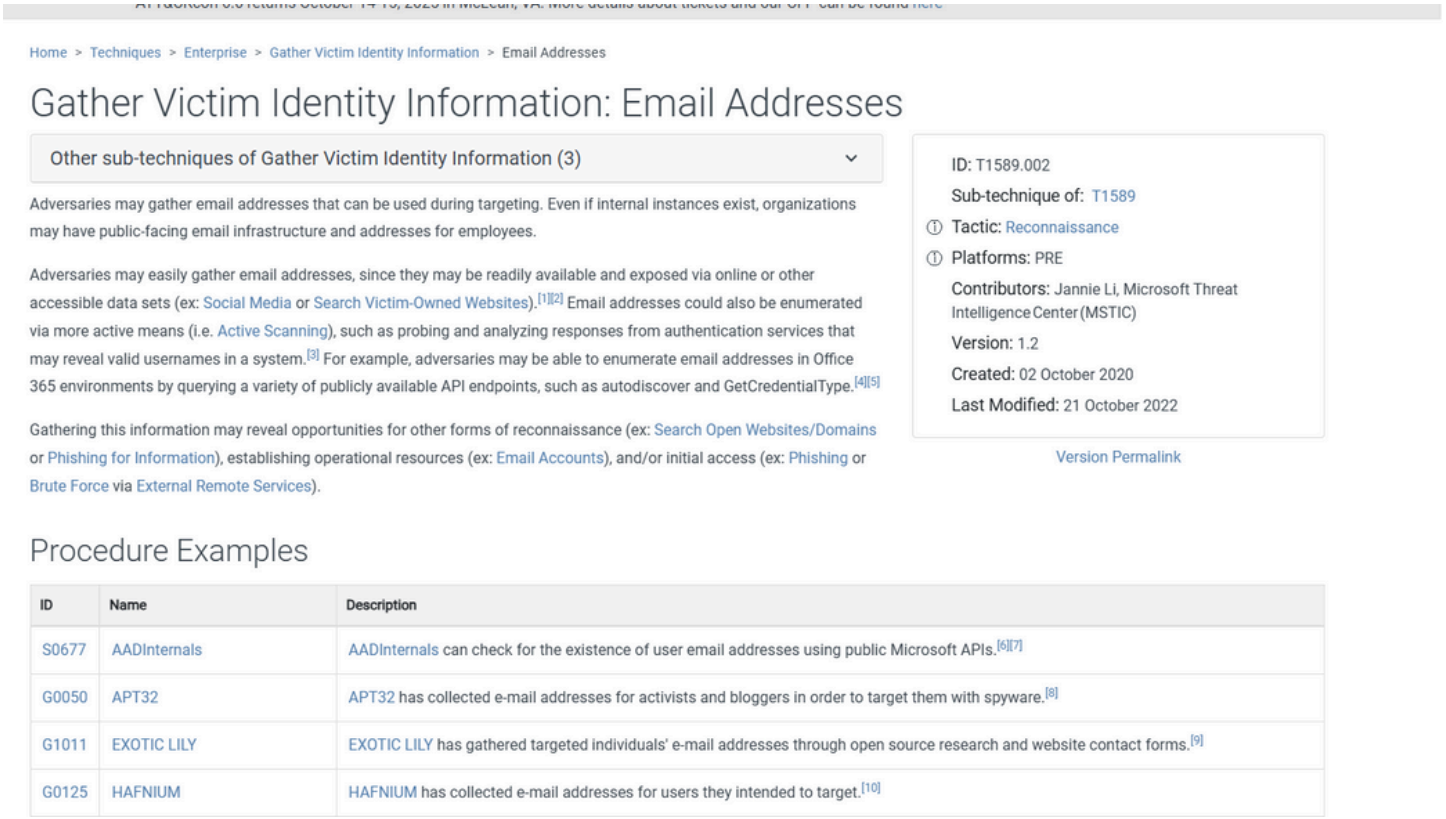
Quelles sont les trois sous-techniques fournies pour cette technique ?

>-Adresses e-mail : Collecte d'adresses e-mail pour cibler des victimes potentielles.

-Profils de réseaux sociaux : Récupération d'informations à partir de profils publics sur des plateformes de réseaux sociaux.

-Recherche de données personnelles : Utilisation de bases de données publiques ou de fuites de données pour obtenir des informations personnelles sur les victimes.

f. Sélectionnez la sous-technique « Adresses e-mail ». Consultez les informations



Home > Techniques > Enterprise > Gather Victim Identity Information > Email Addresses

Gather Victim Identity Information: Email Addresses

Other sub-techniques of Gather Victim Identity Information (3)

Adversaries may gather email addresses that can be used during targeting. Even if internal instances exist, organizations may have public-facing email infrastructure and addresses for employees.

Adversaries may easily gather email addresses, since they may be readily available and exposed via online or other accessible data sets (ex: Social Media or Search Victim-Owned Websites).[1][2] Email addresses could also be enumerated via more active means (i.e. Active Scanning), such as probing and analyzing responses from authentication services that may reveal valid usernames in a system.[3] For example, adversaries may be able to enumerate email addresses in Office 365 environments by querying a variety of publicly available API endpoints, such as autodiscover and GetCredentialType.[4][5]

Gathering this information may reveal opportunities for other forms of reconnaissance (ex: Search Open Websites/Domains or Phishing for Information), establishing operational resources (ex: Email Accounts), and/or initial access (ex: Phishing or Brute Force via External Remote Services).

ID: T1589.002
Sub-technique of: T1589
Tactic: Reconnaissance
Platforms: PRE
Contributors: Jannie Li, Microsoft Threat Intelligence Center (MSTIC)
Version: 1.2
Created: 02 October 2020
Last Modified: 21 October 2022

Version Permalink

Procedure Examples

ID	Name	Description
S0677	AADInternals	AADInternals can check for the existence of user email addresses using public Microsoft APIs.[6][7]
G0050	APT32	APT32 has collected e-mail addresses for activists and bloggers in order to target them with spyware.[8]
G1011	EXOTIC LILY	EXOTIC LILY has gathered targeted individuals' e-mail addresses through open source research and website contact forms.[9]
G0125	HAFNIUM	HAFNIUM has collected e-mail addresses for users they intended to target.[10]

>Le **groupe Lazarus** est un groupe de menaces persistantes avancées (APT) lié à la Corée du Nord. Ce groupe est connu pour ses cyberattaques sophistiquées et a été impliqué dans plusieurs incidents notables, tels que :

-Le piratage de Sony en 2014.

-L'attaque de la Banque centrale du Bangladesh en 2016.

Le groupe Lazarus a mené des campagnes visant à collecter des adresses e-mail pour des attaques ultérieures. Voici comment ils ont généralement procédé :

-Ils utilisent des techniques de phishing et de scraping pour rassembler des adresses e-mail de cibles potentielles. Les adresses collectées sont souvent utilisées pour lancer des attaques de phishing, où des e-mails malveillants sont envoyés pour inciter les victimes à cliquer sur des liens ou à télécharger des fichiers infectés, permettant ainsi au groupe d'accéder à des systèmes sensibles.

Questions de réflexion

1. Vous avez étudié quatre méthodologies de test d'intrusion courantes dans ce laboratoire. Nommez au moins deux autres méthodologies de test d'intrusion couramment utilisées.

>**NIST (National Institute of Standards and Technology)** : Cette méthodologie fournit un cadre rigoureux pour l'évaluation de la sécurité des systèmes d'information, en se concentrant sur l'identification, l'analyse et la correction des vulnérabilités.

ISSAF (Information Systems Security Assessment Framework) : Cette méthodologie est conçue pour évaluer la sécurité des systèmes d'information en utilisant une approche structurée et en se basant sur des normes de sécurité reconnues.

2. Pourquoi est-il important de suivre une méthodologie de pentesting reconnue ?

>-Cela facilite la communication entre les équipes de sécurité et les parties prenantes, en utilisant un langage et des processus communs.

-Une méthodologie éprouvée aide à identifier les vulnérabilités de manière plus efficace,